SOC Level 1 - Laboratoire TryHackMe

Rapport d'Incident de Sécurité

The Greenholt Phish

Analyse d'un e-mail suspect : en-têtes, authentification, infrastructure et pièce jointe

---

Analyste :
Ilyass Jenjare

Date de l'analyse :
14 octobre 2026

Échantillon :
`challenge.eml`

Table des matières

1 Résumé Exécutif **2**

2 Objectifs et Outils **2**

3 Constats Détaillés **3**

3.1 Analyse des en-têtes 3

3.2 Attribution de l'adresse IP source 3

3.3 Vérification SPF 4

3.4 Vérification DMARC 4

3.5 Analyse de la pièce jointe 4

4 Indicateurs de compromission (IOC) **5**

5 Cartographie MITRE ATT&CK **5**

6 Conclusion **5**

7 Recommandations **6**

1 Résumé Exécutif

Un commercial de Greenholt PLC a signalé un e-mail reçu d'un client connu : salutation générique, demande de virement inattendue et pièce jointe non sollicitée. Le message a été escalé au SOC pour analyse.

L'investigation confirme une tentative de phishing, avec les éléments suivants :

— L'authentification SPF échoue : l'IP émettrice n'est pas autorisée à envoyer pour `mutawamarine.com` (usurpation de domaine).

— L'adresse de réponse (`Reply-To`) diffère de l'expéditeur et pointe vers un service de messagerie gratuit.

— La pièce jointe, présentée comme un PDF, est une archive RAR contenant un exécutable Windows, détectée comme malveillante par 49/62 moteurs sur VirusTotal.

2 Objectifs et Outils

Objectifs :

— Extraire les artefacts clés de l'e-mail.

— Déterminer l'origine et l'authenticité du message.

— Évaluer le caractère malveillant du message et de sa pièce jointe.

Outil	**Usage**
Mozilla Thunderbird (vue Source)	Lecture des en-têtes bruts
dig	Interrogation DNS : enregistrements SPF et DMARC
Outil de recherche d'IP / WHOIS	Géolocalisation et propriétaire de l'IP source
sha256sum	Empreinte de la pièce jointe
VirusTotal	Réputation du fichier et relations (fichiers contenus, parents d'exécution)

Table 1 – Outils utilisés lors de l'investigation

3 Constats Détaillés

3.1 Analyse des en-têtes

Élément	Valeur
Objet	Contient la référence de transfert `09674321`
Nom affiché	Mr. James Jackson
Expéditeur / Return-Path	`info@mutawamarine.com`
Reply-To	`info.mutawamarine@mail.com`
IP d'origine	192.119.71.157
Hôte d'envoi	`hwsrv-737338.hostwindsdns.com` (HELO annoncé : `mutawamarine.com`)
Date d'envoi	10 juin 2020

TABLE 2 – Informations extraites des en-têtes de l'e-mail

Résultats d'authentification relevés dans les en-têtes :

```
Received-SPF: fail (domain of mutawamarine.com does not designate x
   .x.x.x as permitted sender)
Authentication-Results: spf=fail smtp.mailfrom=mutawamarine.com;
   dmarc=unknown
```

— Le serveur se présente comme `mutawamarine.com` dans son HELO, mais l'IP réelle ne correspond pas à l'infrastructure autorisée du domaine.

— Le `Reply-To` détourne les réponses vers un compte `mail.com` gratuit, un schéma classique pour capter les échanges de la victime.

— La demande de transfert d'argent avec référence évoque une fraude de type fausse facture / BEC.

3.2 Attribution de l'adresse IP source

Champ	Valeur
IP	192.119.71.157 (IPv4)
Localisation	Dallas, États-Unis
ASN	54290
Plage réseau	192.119.64.0 - 192.119.127.255
Propriétaire	HostPapa
Contact abus	`net-abuse-global@hostpapa.com`

TABLE 3 – Attribution de l'adresse IP d'origine

Il s'agit d'un hébergeur mutualisé grand public, sans lien avec une infrastructure de messagerie d'entreprise. Le nom DNS inverse de l'en-tête (`hostwindsdns.com`) mentionne un autre hébergeur : cet écart illustre l'intérêt de recouper plusieurs sources lors de l'attribution d'une IP.

3.3 Vérification SPF

Commande : `dig txt mutawamarine.com`

```
"v=spf1 include:spf.protection.outlook.com -all"
```

- Seuls les serveurs Microsoft 365 / Outlook sont autorisés à envoyer pour ce domaine.
- `-all` impose un rejet strict (*hard fail*) pour tout autre émetteur.
- L'IP `192.119.71.157` ne figure pas dans cette liste, d'où `spf=fail` : le domaine est usurpé.

3.4 Vérification DMARC

Commande : `dig txt _dmarc.mutawamarine.com`

```
"v=DMARC1; p=quarantine; fo=1"
```

- `p=quarantine` : les messages en échec DMARC doivent être placés en quarantaine.
- `fo=1` : rapport d'échec demandé si SPF ou DKIM échoue.
- Aucun champ `rua` : le propriétaire ne reçoit pas de rapports agrégés ; une politique `p=reject` renforcerait la protection.
- Côté récepteur, le résultat DMARC apparaît `unknown` et le message a tout de même été délivré.

3.5 Analyse de la pièce jointe

Élément	Valeur
Nom du fichier	`SWT_#09674321____PDF__.CAB`
Taille	400,26 KB
SHA-256	`2e91c533615a9bb8929ac4bb76707b2444597ce063d84a4b33525e25074fff3f`
Type réel	RAR (ni CAB, ni PDF)

TABLE 4 – Propriétés de la pièce jointe

VirusTotal :

- 49 / 62 éditeurs signalent l'archive comme malveillante ; étiquettes : `rar`, `spreader`, `attachment`.
- Fichier contenu : `SWT_#09674321__PDF.com`, exécutable Win32 EXE détecté par 58 / 71 moteurs.

— L'archive est liée à l'e-mail `challenge.eml` et à un ZIP protégé par mot de passe (`PW_infected_...`).

Techniques de dissimulation :

— Extension trompeuse : « PDF » dans le nom, extension `.CAB`, type réel RAR.

— Double extension : le fichier contenu imite un PDF mais est un exécutable (`.com`).

— Archive : peut contourner les filtres basés sur l'extension.

4 Indicateurs de compromission (IOC)

Type	Valeur
Domaine usurpé	`mutawamarine.com`
Adresse d'expéditeur	`info@mutawamarine.com`
Adresse Reply-To	`info.mutawamarine@mail.com`
Adresse IP	`192.119.71.157`
Nom d'hôte	`hwsrv-737338.hostwindsdns.com`
Pièce jointe	`SWT_#09674321____PDF__.CAB`
Fichier extrait	`SWT_#09674321__PDF.com`
SHA-256	`2e91c533615a9bb8929ac4bb76707b2444597ce063d84a4b33525e25074fff3f`
Référence de leurre	`09674321`

TABLE 5 – Liste des Indicateurs de Compromission (IOC)

5 Cartographie MITRE ATT&CK

Tactique	ID	Technique
Initial Access	T1566.001	Phishing : pièce jointe (Spearphishing Attachment)
Execution	T1204.002	User Execution : fichier malveillant
Defense Evasion	T1036.007	Masquerading : double extension de fichier
Resource Development / Initial Access	T1656	Usurpation d'identité (Impersonation)

TABLE 6 – Mapping des techniques d'attaque observées

6 Conclusion

L'e-mail est malveillant. Le faisceau d'indices est cohérent : échec SPF et usurpation du domaine, `Reply-To` détourné, pièce jointe déguisée en PDF mais composée d'une archive RAR contenant un exécutable Windows, forte détection sur VirusTotal (49/62 et 58/71) et contexte de fraude financière.

7 Recommandations

Réponse immédiate :

— Bloquer l'IP, les adresses e-mail et le hash listés dans les IOC.

— Rechercher et supprimer le message dans toutes les boîtes de réception.

— Identifier les destinataires ayant ouvert la pièce jointe ; isoler et analyser les postes concernés.

— Contacter le client réel par un canal alternatif pour l'informer de l'usurpation.

Prévention :

— Mettre en quarantaine ou bloquer les archives et exécutables entrants (`.rar`, `.cab`, `.com`, `.exe`).

— Faire respecter strictement SPF/DKIM/DMARC en réception.

— Côté domaine usurpé : passer DMARC à `p=reject` et activer les rapports (`rua`).

— Former les utilisateurs : valider toute demande de paiement par un second canal et signaler les messages suspects.